

Mejora definitiva DOC tecnica monitoreo

Divier Jácamo Álvarez

Cetav La Libertad

Rol: Analista SOC L1

Fecha: Jueves 26/03/26

introducción

Los SOC se han convertido en una parte esencial de las organizaciones actuales debido a las cada vez mayores amenazas cibernéticas, ataques informáticos y vulnerabilidades en la infraestructura tecnológica.

Hoy en día, las empresas dependen en gran medida de sus sistemas de información, por lo que la seguridad informática se convierte en una prioridad estratégica para garantizar la continuidad del negocio y la protección de la información.

La función principal de un SOC es monitorear, detectar, analizar y responder a incidentes de seguridad en tiempo real.

Esto incluye el monitoreo continuo de redes, servidores, endpoints, aplicaciones y sistemas de autenticación para identificar comportamientos anómalos o actividades maliciosas que podrían comprometer la seguridad de la organización.

El propósito de este documento es describir la optimización de los procesos de monitoreo dentro del SOC, enfocándose en mejorar la detección de incidentes, reducir los falsos

positivos, optimizar la gestión de alertas y mejorar el tiempo de respuesta ante incidentes de seguridad.

Al optimizar estos procesos, puede mejorar la eficiencia operativa del SOC y fortalecer la postura de seguridad de su organización.

2. Marco teórico

Un Centro de Operaciones de Seguridad (SOC) es una unidad organizacional responsable de monitorear, detectar, investigar y responder a incidentes de seguridad informática.

SOC trabaja continuamente y analiza eventos de seguridad generados por diversos dispositivos y sistemas de la infraestructura tecnológica.

Uno de los componentes clave de un SOC es un sistema SIEM que le permite recopilar, almacenar, analizar y correlacionar eventos de seguridad de múltiples fuentes, como firewalls, servidores, sistemas operativos, aplicaciones, antivirus, sistemas de detección de intrusos y dispositivos de red.

SIEM permite centralizar la información y generar alertas cuando se detecta actividad sospechosa.

Además, el sistema MITRE ATT&CK proporciona una base de conocimientos de las tácticas, técnicas y procedimientos utilizados por los atacantes.

Este marco se utiliza ampliamente en ciberseguridad para mejorar la detección de amenazas a través de la correlación de eventos basada en el comportamiento, lo que permite identificar ataques incluso en ausencia de firmas conocidas.

Por otro lado, existen métricas utilizadas para medir el rendimiento y la eficiencia del SOC, entre las que destacan MTTD y MTTR

MTTD mide el tiempo promedio que le toma a un equipo de seguridad detectar un incidente, mientras que MTTR mide el tiempo promedio que toma responder y solucionar un incidente.

Estas mediciones permiten evaluar la efectividad del funcionamiento del SOC y revelar oportunidades para mejorar los procesos de seguimiento.

Método

Para la elaboración de este documento se utilizó un método basado en simulaciones teóricas de incidentes de seguridad para evaluar el desempeño de los procesos de monitoreo dentro del SOC.

Estas simulaciones nos permitieron analizar el comportamiento del sistema de vigilancia frente a diferentes tipos de incidentes de seguridad.

Durante el proceso, se generaron eventos controlados como intentos de acceso no autorizados, ejecución de archivos sospechosos, múltiples intentos fallidos de autenticación y tráfico de red anormal. Estos eventos fueron recopilados por el sistema SIEM, donde se activaron reglas de correlación preconfiguradas.

Luego se analizaron las alertas generadas por el sistema y se midieron métricas clave como el tiempo de detección (MTTD), el tiempo de respuesta (MTTR), los falsos positivos y la eficacia de la gestión de alertas.

Esta metodología permitió identificar oportunidades de mejora de los procesos de seguimiento y gestión de incidencias.

4. arquitectura SOC

La arquitectura SOC se basa en un modelo de monitoreo centralizado donde toda la información de seguridad se envía a un sistema SIEM central para su análisis y correlación.

Este modelo proporciona visibilidad total de la infraestructura tecnológica y facilita la detección de incidentes de seguridad.

La infraestructura SOC integra múltiples fuentes de información, que incluyen:

Dispositivos de seguridad de red

Puntos finales

Servidores críticos

Sistemas de autenticación

Infraestructura de red

Aplicaciones empresariales

Toda la información recopilada se envía a un sistema SIEM donde los registros se normalizan para estandarizar los formatos de eventos.

Luego, los eventos se correlacionan mediante reglas para identificar patrones de ataque o comportamientos sospechosos.

Esta arquitectura permite una gestión de seguridad centralizada, capacidades de monitoreo mejoradas y una respuesta más sencilla.

5. Flujo de procesamiento de información

En el flujo de procesamiento de la información, el SOC realiza una serie de pasos que permiten convertir los eventos de seguridad en alertas que pueden ser analizadas por los analistas de seguridad.

El flujo de procesamiento incluye las siguientes fases:

Colección → Normalización → Correlación → Generación de alarmas → Análisis →

Respuesta

La fase de recopilación captura registros y eventos de varios dispositivos y sistemas.

Luego, la fase de normalización transforma los eventos en un formato estándar para facilitar su análisis.

Luego, en el paso de correlación, los eventos se analizan juntos para identificar patrones de ataque o comportamientos inusuales. Cuando se detecta actividad sospechosa, el sistema genera una alerta que se envía a los analistas de SOC para su análisis.

Finalmente, el analista investiga la alerta y determina la respuesta adecuada para contener o mitigar el incidente de seguridad.

6.

Monitoreo de procesos

Los procesos de seguimiento dentro del SOC son esenciales para garantizar la detección temprana de incidentes de seguridad.

Estos procesos incluyen recopilación continua de eventos, normalización de registros, enriquecimiento de datos, correlación de eventos y priorización de alarmas.

El enriquecimiento de datos implica agregar información adicional a los eventos, como la reputación de la dirección IP, dominios maliciosos, ubicación geográfica o indicadores de amenazas. Esto mejora el análisis de eventos y reduce los falsos positivos.

La correlación basada en MITRE ATT&CK ayuda a identificar tácticas y técnicas utilizadas por los atacantes, mejorando la detección avanzada de amenazas.

Además, la priorización de alertas permite a los analistas centrarse primero en los incidentes más importantes.

7. Gestión de alarmas

La gestión de alertas es un proceso crítico en SOC, ya que una gran cantidad de alertas puede crear saturación y afectar la capacidad de respuesta del equipo de seguridad.

Por este motivo, es necesario implementar mecanismos que reduzcan el ruido operacional.

Entre los métodos utilizados para gestionar las alertas se encuentran:

Agrupación de eventos

Exclusión de alertas inapropiadas

Clasificación de dificultad

Priorización de incidentes

Automatización de respuestas

La clasificación de gravedad permite priorizar los incidentes para su atención.

Descripción del nivel

Críticas Compromiso de datos o servicios críticos

Intentos de intrusión importantes o detección de malware

Anomalías moderadas sin impacto inmediato

Medidas de baja información

Esta clasificación permite mejorar la eficiencia operativa del SOC y reducir el tiempo de respuesta ante incidentes críticos.

8. Análisis y respuesta a incidentes.

El análisis de eventos consiste en comprobar las alertas generadas por el sistema de seguimiento para determinar si se trata de un evento real o un falso positivo.

Durante este proceso, se recopilan pruebas, se revisan los registros, se analizan las direcciones IP, los usuarios involucrados y el comportamiento del sistema.

El proceso de respuesta a incidentes incluye las siguientes fases:

Reconocimiento de alarma

Recopilación de pruebas

Clasificación de eventos

Escalada

respuesta

Documentación del incidente

Los pasos de respuesta pueden ser automatizados o manuales según la naturaleza crítica del incidente.

Algunos pasos incluyen bloquear direcciones IP, aislar computadoras, eliminar malware, deshabilitar cuentas comprometidas y restaurar sistemas.

9. Indicadores de desempeño

Se utilizaron varios indicadores de desempeño relacionados con la detección y respuesta a incidentes para medir la efectividad del SOC.

Indicadores de desempeño

Reducción del 40% en alertas duplicadas

Reducción del tiempo de entrega en un 35%

Los falsos positivos se reducen un 30%

MTTD 12 minutos

MTTR 45 minutos

MTTD es el tiempo promedio que le toma a un SOC detectar un incidente de seguridad, mientras que MTTR es el tiempo promedio que le toma responder y solucionar un incidente.

Estos indicadores se utilizan para evaluar la eficiencia operativa del SOC.

10. resultados

Los resultados obtenidos indican una mejora significativa en la eficiencia de la operación del SOC.

Implementar reglas de correlación más precisas, optimizar la gestión de alertas y automatizar algunos procesos nos permitió reducir la carga operativa de los analistas y mejorar los tiempos de respuesta.

Sin embargo, aún quedan desafíos importantes, como la detección de amenazas avanzadas, ataques de día cero y la dependencia de reglas predefinidas.

Por este motivo, es necesario implementar inteligencia de amenazas y mejorar continuamente las reglas de detección.

La seguridad informática es un proceso continuo, por lo que el SOC debe mejorarse y actualizarse constantemente para adaptarse a las nuevas amenazas.

11. Riesgos y limitaciones

Limitación de riesgo

Dependencia SIEM Redundancia y conmutación por error

Optimización de la regla de saturación de alarmas

Falsos negativos Mejora continua en la detección

Falta de personal especializado Formación continua

Estos riesgos pueden afectar el desempeño del COS, por lo que es importante implementar estrategias de mitigación para reducir su impacto.

12. Recomendaciones

Se recomienda implementar inteligencia de amenazas en tiempo real para mejorar la detección de ataques avanzados.

Además, se recomienda automatizar procesos utilizando herramientas SOAR para reducir el tiempo de respuesta a incidentes.

También es importante educar continuamente al personal del SOC sobre nuevas amenazas, herramientas de seguridad y técnicas de análisis de incidentes.

La mejora continua de los procesos de seguimiento permitirá mantener un SOC eficaz y prepararse para nuevas amenazas.

Conclusión

Optimizar los procesos de monitorización en un SOC permite mejorar significativamente la detección y respuesta ante incidentes de seguridad informática.

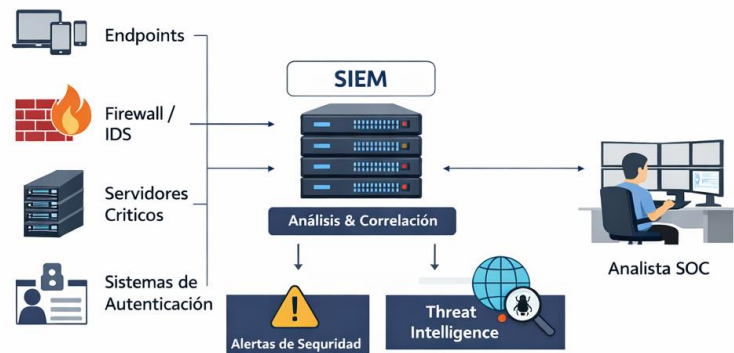
La integración de herramientas SIEM, marcos como MITRE ATT&CK y marcos de seguridad como NIST fortalece la postura de seguridad de una organización.

Además, la gestión mejorada de alertas, la automatización de procesos y la capacitación del personal ayudan a mejorar la eficiencia operativa del SOC.

La seguridad informática debe verse como un proceso de mejora continua que requiere una actualización constante de herramientas, procesos y conocimientos del personal.

En conclusión, un SOC bien estructurado y con procesos optimizados permite reducir los riesgos de seguridad, mejorar la detección de amenazas y garantizar la protección de la información y los sistemas de la organización.

Arquitectura del SOC



Flujo de Procesos de Monitoreo



Referencias

Kent, K., & Souppaya, M. (2006). *Guide to Computer Security Log Management (NIST SP 800-92)*. National Institute of Standards and Technology.

<https://doi.org/10.6028/NIST.SP.800-92>

National Institute of Standards and Technology. (2012). *Computer Security Incident Handling Guide (NIST SP 800-61r2)*.

<https://doi.org/10.6028/NIST.SP.800-61r2>

National Institute of Standards and Technology. (2018). *Framework for Improving Critical Infrastructure Cybersecurity*.

<https://www.nist.gov/cyberframework>

ENISA. (2023). *Security Operations Centre (SOC) Best Practices*.

<https://www.enisa.europa.eu/publications/security-operations-centre-soc-best-practices>

MITRE. (2023). *MITRE ATT&CK Framework*.

<https://attack.mitre.org/>